GUÍA DE ESTUDIO

Arquitecturas Híbridas y Seguridad en Cloud: AWS, Azure y GCP

UNIDAD	SESIÓN	TIPO	NIVEL
2	5	ESTUDIO	AVANZADO

CUGDL - Universidad de Guadalajara
Arquitectura de Sistemas de Seguridad
Licenciatura en Ciberseguridad

Autor: Carlos Pulido Rosas
Abril 2026

OBJETIVOS DE APRENDIZAJE

1. Distinguir los modelos de despliegue cloud (IaaS, PaaS, SaaS) y entender qué responsabilidades de seguridad recaen en el cliente en cada modelo.
2. Describir los componentes de seguridad equivalentes en cloud a los que ya conoces en redes on-premise: VPC, Security Groups, subnets, y WAF cloud.
3. Comparar los tres modelos de arquitectura: on-premise, cloud puro e híbrido, e identificar los vectores de ataque específicos de cada uno.
4. Aplicar el principio de Shared Responsibility Model para determinar qué protege el proveedor cloud y qué debe proteger la organización.

CONTEXTO

Todo lo que viste en las sesiones anteriores — DMZ, VLANs, NGFW, IDS/IPS, VPNs — fue diseñado para infraestructura on-premise donde tú controlas el hardware físico. En cloud, alguien más controla el hardware y tú controlas la configuración. Ese cambio de modelo tiene implicaciones profundas de seguridad que esta guía explora.

El caso real de Capital One que vimos en la Sesión 6 fue exactamente un fallo de arquitectura cloud mal configurada. Ahora que entiendes los conceptos, puedes analizar qué falló específicamente y cómo debería haberse diseñado.

1. Modelos de Servicio Cloud: IaaS, PaaS, SaaS

Antes de hablar de seguridad en cloud hay que entender qué controla la organización y qué controla el proveedor. Esta distinción determina directamente quién es responsable de cada capa de seguridad.

Capa	On-Premise	IaaS	PaaS	SaaS
Hardware físico	Tú	Proveedor	Proveedor	Proveedor
Red física	Tú	Proveedor	Proveedor	Proveedor
Virtualización	Tú	Proveedor	Proveedor	Proveedor
Sistema operativo	Tú	Tú	Proveedor	Proveedor
Runtime / plataforma	Tú	Tú	Proveedor	Proveedor
Aplicación	Tú	Tú	Tú	Proveedor
Datos	Tú	Tú	Tú	Tú (siempre)
Identidad y acceso	Tú	Tú	Tú	Tú (siempre)

La última fila es la más importante: los datos y la identidad son siempre responsabilidad de la organización, sin importar el modelo de servicio. Un proveedor cloud puede proteger perfectamente su infraestructura física y aun así ocurrir una brecha si la organización configura mal sus permisos de acceso o expone datos públicamente.

ANALOGÍA — Modelos cloud como servicios de cocina

On-premise: construyes tu propia cocina, compras el equipo, contratas cocineros y decides el menú. Control total, responsabilidad total.

IaaS: alquilas una cocina equipada (AWS EC2, Azure VM). El edificio y los electrodomésticos son del arrendador, pero tú traes los ingredientes, cocinas y decides el menú.

PaaS: el restaurante te da la cocina, los utensilios y los cocineros base (AWS Elastic Beanstalk, Azure App Service). Tú solo traes la receta y los ingredientes especiales.

SaaS: pides delivery (Gmail, Salesforce). Solo decides qué pedir. Todo lo demás es del proveedor.

2. Shared Responsibility Model

El Shared Responsibility Model (Modelo de Responsabilidad Compartida) es el framework conceptual que todos los proveedores cloud usan para definir qué protegen ellos y qué debe proteger el cliente. Entenderlo mal es la causa de la mayoría de las brechas en cloud.

La regla general es simple: el proveedor protege la seguridad del cloud (la infraestructura física, la red, el hipervisor), y el cliente protege la seguridad en el cloud (lo que despliega encima: datos, aplicaciones, configuración de acceso).

Lo que el proveedor SIEMPRE protege (seguridad DEL cloud)

- Seguridad física de los datacenters — acceso físico, vigilancia, controles ambientales.
- Red física y virtualización — el hipervisor que corre tus VMs está protegido por el proveedor.
- Disponibilidad de la infraestructura — SLAs de uptime, redundancia de hardware.
- Cumplimiento de certificaciones base — ISO 27001, SOC 2, PCI DSS a nivel de infraestructura.

Lo que el cliente SIEMPRE protege (seguridad EN el cloud)

- Configuración de acceso e identidad (IAM) — quién puede acceder a qué recursos y con qué permisos.
- Cifrado de datos en reposo y en tránsito — el proveedor ofrece las herramientas, el cliente debe activarlas.
- Configuración de red — Security Groups, NACLs, qué puertos están abiertos y hacia dónde.
- Parchado del sistema operativo — en IaaS el cliente es responsable de actualizar el SO de sus VMs.
- Configuración de las aplicaciones — vulnerabilidades en el código y dependencias son responsabilidad del cliente.

CASO REAL: Capital One 2019 — fallo de Shared Responsibility

El ataque a Capital One es el ejemplo más citado de fallo del Shared Responsibility Model. AWS cumplió perfectamente su parte: la infraestructura física era segura, el hipervisor era seguro, los datacenters eran seguros.

El fallo fue en la parte del cliente: una misconfiguration en el WAF permitió un ataque SSRF que obtuvo credenciales IAM temporales con permisos excesivos sobre buckets de S3. Capital One configuró mal su WAF (responsabilidad del cliente), asignó permisos IAM demasiado amplios (responsabilidad del cliente), y no tenía detección de anomalías configurada para ese patrón de acceso (responsabilidad del cliente).

AWS no falló. Capital One falló en su parte del modelo compartido.

3. Equivalencias: on-premise vs. cloud

Los conceptos de seguridad que aprendiste en las sesiones anteriores tienen equivalentes directos en cloud. Entender estas equivalencias te permite aplicar los mismos principios de arquitectura en cualquier entorno.

On-premise	AWS	Azure	GCP	Función
Red interna	VPC (Virtual Private Cloud)	Virtual Network (VNet)	VPC	Red privada virtual aislada
Subred / VLAN	Subnet (pública o privada)	Subnet	Subnet	Segmento de red dentro de la VPC
Firewall perimetral	Security Group + NACL	NSG (Network Security Group)	Firewall Rules	Control de tráfico entrante/saliente
DMZ	Subnet pública + ALB	DMZ subnet + App Gateway	Public subnet + Load Balancer	Zona expuesta a Internet
Servidor interno	EC2 en subnet privada	VM en subnet privada	Compute Engine privada	Instancia sin IP pública
WAF	AWS WAF + Shield	Azure WAF + DDoS Protection	Cloud Armor	Protección capa 7
IDS/IPS	AWS GuardDuty + Inspector	Microsoft Defender for Cloud	Security Command Center	Detección de amenazas
SIEM	AWS Security Hub + CloudTrail	Microsoft Sentinel	Chronicle SIEM	Centralización y correlación
VPN site-to-site	AWS Site-to-Site VPN	Azure VPN Gateway	Cloud VPN	Conexión segura on-premise ↔ cloud

4. VPC — La Red Privada en Cloud

Una VPC (Virtual Private Cloud) es el equivalente en cloud de tu red interna on-premise con VLANs. Es un espacio de red lógicamente aislado dentro del cloud del proveedor donde tú controlas el rango de IPs, la segmentación en subnets, las tablas de enrutamiento y los controles de acceso.

4.1 Subnets públicas vs. privadas

El concepto más importante de diseño en una VPC es la distinción entre subnets públicas y privadas. Esta distinción replica el concepto de DMZ que ya conoces — los recursos que necesitan ser accesibles desde Internet van en subnets públicas, los que no deben ser accesibles directamente van en subnets privadas.

Tipo	Acceso desde Internet	Qué va aquí	Equivalente on-premise
Subnet pública	Sí — tiene Internet Gateway	Load balancer, NAT Gateway, servidores web	DMZ
Subnet privada	No — solo tráfico interno	Bases de datos, servidores de aplicación, servicios internos	Red interna

ANALOGÍA — VPC como tu red corporativa en la nube

La VPC es el edificio que alquilas en el cloud — tú decides cómo dividir los pisos (subnets), qué puertas tienen acceso desde la calle (Internet Gateway) y cuáles solo conectan pisos internos (routing privado).

El proveedor construyó y mantiene el edificio. Tú decides la distribución interna, quién tiene llave de qué puerta y qué cámaras de seguridad instalas.

A diferencia de on-premise, si configuras mal una puerta (Security Group con 0.0.0.0/0), el resultado es visible en Internet en segundos — no en días como en un firewall físico mal configurado.

4.2 Security Groups y NACLs

En cloud hay dos capas de control de tráfico de red que operan en niveles distintos y se complementan, equivalentes a tener un firewall en la instancia y otro en el switch.

Criterio	Security Group	NACL (Network ACL)
Nivel de aplicación	Instancia (EC2, RDS)	Subnet completa
Tipo de reglas	Solo Allow — no hay reglas de Deny explícitas	Allow y Deny explícitos
Stateful / Stateless	Stateful — respuestas automáticas permitidas	Stateless — debes permitir el tráfico de retorno
Evaluación	Todas las reglas se evalúan juntas	Reglas evaluadas en orden numérico
Equivalente on-premise	Firewall en el host (Windows Firewall, iptables)	ACL en el switch o router

5. Arquitectura Híbrida

Una arquitectura híbrida combina infraestructura on-premise con cloud, conectadas de forma segura. Este es el escenario más común en empresas medianas y grandes en México — no migraron todo a cloud de golpe sino que mantienen sistemas críticos on-premise (ERP, base de datos de nómina, sistemas legacy) y mueven cargas de trabajo más flexibles a cloud (web, APIs, analytics).

5.1 Modelos de conectividad híbrida

Método	Tecnología	Seguridad	Cuándo usarlo
VPN site-to-site	IPsec sobre Internet	Cifrado en tránsito, depende de Internet	Conexión económica para cargas no críticas
Dedicated connection	AWS Direct Connect / Azure ExpressRoute	Línea privada dedicada, no pasa por Internet	Datos sensibles, baja latencia, alto volumen
SD-WAN	Overlay sobre múltiples conexiones	Cifrado + redundancia automática	Múltiples sedes con conexión flexible a cloud

5.2 Vectores de ataque específicos de arquitecturas híbridas

La arquitectura híbrida introduce vectores de ataque que no existen en entornos puramente on-premise o puramente cloud. El más crítico es el movimiento lateral entre entornos: si un atacante compromete un sistema on-premise con conectividad a la VPC, puede moverse hacia recursos cloud, y viceversa.

Vectores de ataque más comunes en arquitecturas híbridas

- Credenciales IAM comprometidas — a diferencia de on-premise donde un atacante necesita acceso a la red, en cloud unas credenciales IAM filtradas dan acceso desde cualquier lugar del mundo.
- Misconfiguration de Security Groups — abrir puertos innecesarios a 0.0.0.0/0 (todo Internet) es el error más común y el más detectado por atacantes con herramientas de escaneo automatizado.
- S3 buckets públicos — almacenamiento configurado como público por error. Hay herramientas que escanean todos los buckets de AWS buscando configuraciones públicas con datos sensibles.
- Movimiento lateral on-premise → cloud — un sistema on-premise comprometido con acceso VPN a la VPC puede ser el punto de entrada a la infraestructura cloud.
- Privilege escalation en IAM — políticas IAM mal configuradas que permiten a un usuario o rol asumir permisos más altos de los necesarios.

6. Los mismos principios, nuevo entorno

Los principios de diseño que aprendiste en la Unidad 1 aplican exactamente igual en cloud. Lo que cambia es la herramienta, no el concepto.

Principio	On-premise	Equivalente en cloud
Defensa en profundidad	NGFW + VLANs + IDS/IPS + cifrado	WAF + Security Groups + GuardDuty + KMS
Mínimo privilegio	Roles de AD con permisos específicos	Políticas IAM con permisos granulares por recurso

Segmentación	VLANs separadas por función	Subnets públicas/privadas + Security Groups por tier
Zero Trust	Verificación continua de identidad	IAM + MFA + políticas basadas en contexto (IP, hora, dispositivo)
Monitoreo continuo	SIEM + logs de red	CloudTrail + GuardDuty + Security Hub + SIEM

CASO REAL: Misconfiguration masiva de S3 — patrón recurrente (2017-2024)

Entre 2017 y 2024 se documentaron cientos de incidentes donde organizaciones expusieron datos sensibles en buckets de S3 configurados públicamente por error. Casos notables incluyen datos de 198 millones de votantes estadounidenses (Deep Root Analytics, 2017), registros médicos de 150,000 pacientes (Systema Healthcare, 2023) y código fuente propietario de múltiples empresas Fortune 500.

El patrón es siempre el mismo: un desarrollador crea un bucket para compartir archivos temporalmente, lo configura como público por conveniencia, y nadie lo revierte. Semanas o meses después, un escáner automatizado encuentra el bucket y los datos quedan expuestos.

Conexión con esta guía: es un fallo directo del Shared Responsibility Model. AWS nunca expuso esos datos — AWS ofrece la opción de hacerlo público y el cliente la activó. El control que habría prevenido todos estos incidentes es una política IAM que bloquee la configuración pública de buckets a nivel de organización (AWS SCPs) — que es exactamente el tipo de control de mínimo privilegio que ya conoces, aplicado a la capa de configuración cloud.

PREGUNTAS DE REFLEXIÓN

1. Una empresa mexicana de retail opera su sistema de punto de venta (POS) on-premise pero quiere migrar su plataforma de e-commerce a cloud. Diseña una arquitectura híbrida que conecte ambos entornos de forma segura, identifica los tres vectores de ataque más críticos de esa arquitectura y propón un control específico para cada uno.
2. Un desarrollador de tu equipo argumenta que los Security Groups son suficientes y que las NACLs son redundantes e innecesarias. ¿Estás de acuerdo? Explica en qué escenario específico una NACL protege algo que un Security Group no puede proteger.
3. El Shared Responsibility Model implica que el cliente es siempre responsable de sus datos, incluso en SaaS. ¿Qué implicaciones tiene esto para una empresa que usa Google Workspace o Microsoft 365 para procesar datos sensibles de clientes? ¿Qué controles de seguridad siguen siendo responsabilidad de la empresa aunque use SaaS?

RECURSOS

- [Docs] AWS Shared Responsibility Model — https://aws.amazon.com/compliance/shared-responsibility-model/ — gratuito
- [Docs] AWS Well-Architected Framework — Security Pillar — https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/ — gratuito
- [Docs] Azure Security Benchmark — https://learn.microsoft.com/en-us/security/benchmark/azure/ — gratuito
- [Docs] NIST SP 800-144 — Guidelines on Security and Privacy in Public Cloud Computing — https://csrc.nist.gov/publications/detail/sp/800-144/final — gratuito
- [Video] AWS re:Invent — 'Architecting for Security on AWS' — https://youtube.com/@AWSEventsChannel — aprox. 45 min
- [TryHackMe] Room: 'Cloud Security Basics' — https://tryhackme.com/room/cloudsecuritybasics